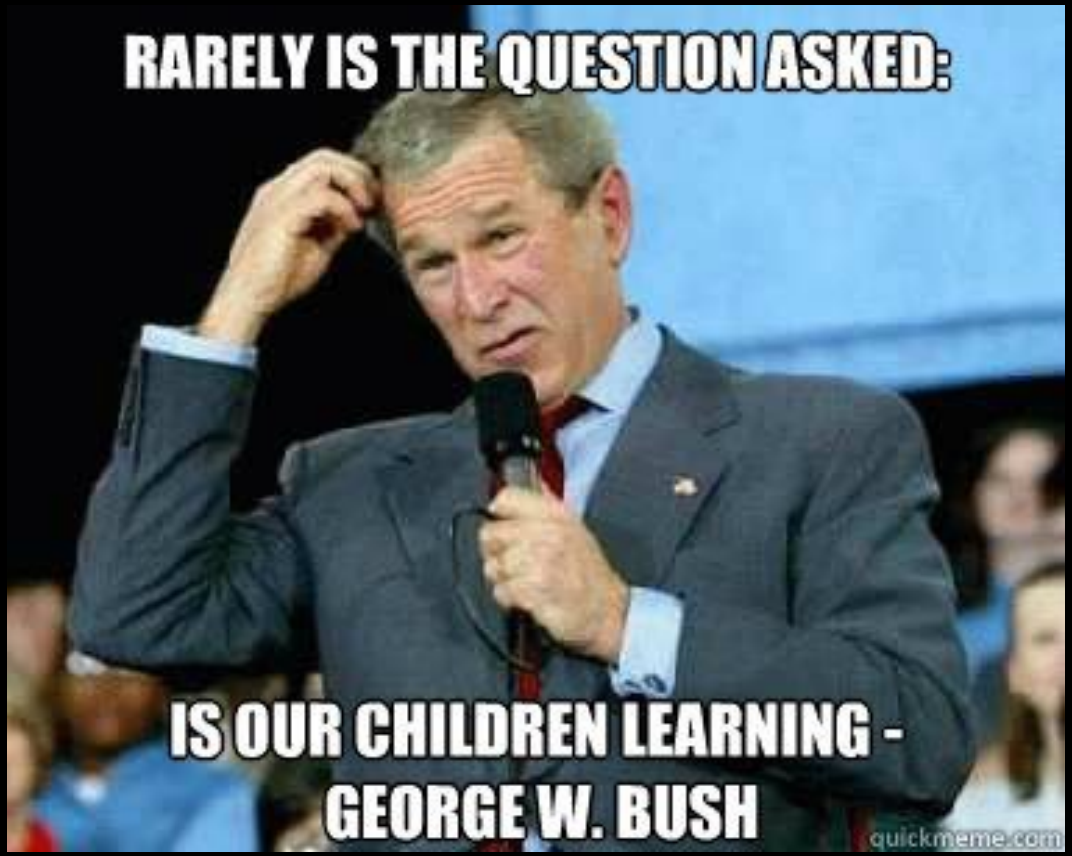

Um Guia Super Resumido Sobre:
Security Compliance em MacOS

Comparando os Três Porquinhos
Mac x Windows x Linux



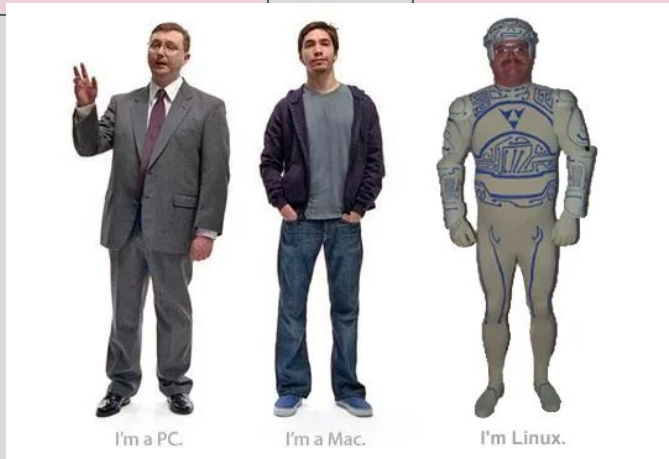
Bem vindos a Twilight Zone!

Vem do Windows?

- Então prepara: no mundo Apple não rola aquele ‘controle total’
- Aqui você não manda — você *pede com jeitinho* via MDM. Tudo respeitando a privacidade do usuário
- Para sobreviver corre pra aprender ABM e a tal filosofia declarativa do MDM

Vem do Linux?

- Fica o aviso: o ecossistema Apple vai parecer puro gesso!
  Não rola esfolar o sistema ou sair hackeando tudo
- Aqui, em vez de scripts malucos, você vai viver configurando perfis numa GUI de MDM
- Segurança? Não é você quem constrói, você configura *dentro do que a Apple deixa*



Visão Geral Comparativa

1. Filosofia & Poder do Admin

- **Apple:** Jardim murado.
  - Admin **não manda em tudo**
    - SIP, TCC e privacidade mandam mais que você
- **Windows:** Território do **admin supremo**.
  - GPO, Registry e controle total
- **Linux: Root é Deus**
  - Liberdade total (inclusive pra quebrar tudo)

2. Gestão & Provisionamento

- **Apple:** Tudo via **MDM + ABM**, modelo **declarativo**: “estado desejado”
  - Sem scripts mágicos aqui!
- **Windows: Imperativo:** GPO/Intune “faz isso agora”
- **Linux:** SSH + scripts + Ansible
  - Do jeito que você quiser.

3. Software

- **Apple:** App Store, PKG, notarização, Gatekeeper. **Controle everywhere**
- **Windows:** EXE/MSI, SCCM/Intune, WinGet. Instalou? Valeu
- **Linux:** Repositórios (`apt`, `dnf`), Snap/Flatpak e… **compila aí se quiser**

4. Segurança

- **Apple:** Segurança **obrigatória**: FileVault, SIP, TCC, Secure Enclave
- **Windows:** Segurança **configurável**: BitLocker, Defender, GPO
- **Linux:** Segurança **DIY**: LUKS, iptables, SELinux. Nada vem pronto.

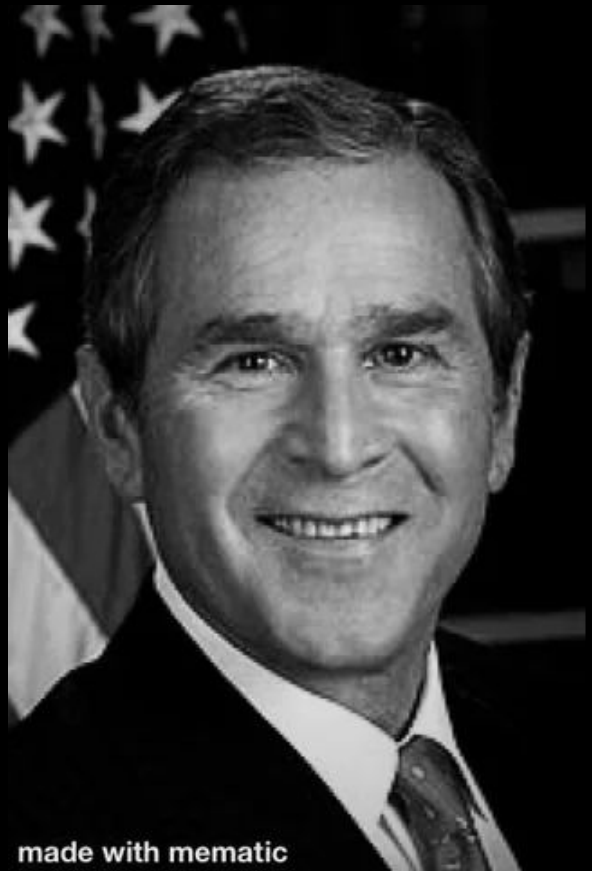
Visão Geral Comparativa

5. Linha de Comando

- **Apple:** Zsh + ferramentas nativas, mas **limitado pelo SIP/TCC**.
- **Windows: PowerShell manda na parada.**
- **Linux:** Shell raiz: Bash + ferramentas Unix. Scripts para tudo

Característica	Apple Ecosystem (macOS/iOS)	Microsoft Windows	Linux
Filosofia	Usabilidade e Privacidade First	Compatibilidade e Controle Corporativo	Liberdade e Flexibilidade Total
Controle do Administrador	Limitado e Delineado pela Apple	Quase Ilimitado	Absoluto (root)
Gestão Centralizada	MDM + ABM/ASM (Obrigatório para escala)	Group Policy (GPO) + Intune/SCCM	Ansible/Puppet/Chef + SSH
Modelo de Implantação	Declarativo (Estado Desejado)	Imperativo (Scripts/Políticas)	Imperativo/Declarativo (Scripts/Config Management)
Repositório de Software	App Store Curada + PKGs manuais	MSI/EXE (Diversas fontes)	Repositórios de Pacotes (apt, yum) + código fonte
Customização do SO	Muito Baixa (SIP, TCC)	Alta (Registry, Políticas)	Ilimitada (Kernel up)
Segurança Nativa	Obrigatória e altamente padronizada (SIP, Gatekeeper, Notarization)	Configurável (Defender, BitLocker)	DIY (iptables, SELinux/AppArmor)

Defesas da Apple & Como São Burladas



Our enemies are innovative and resourceful, and so are we. They never stop thinking about new ways to harm our country and our people and neither do we.

– *George W Bush 2004*

Abuso de Ferramentas do Próprio MacOS

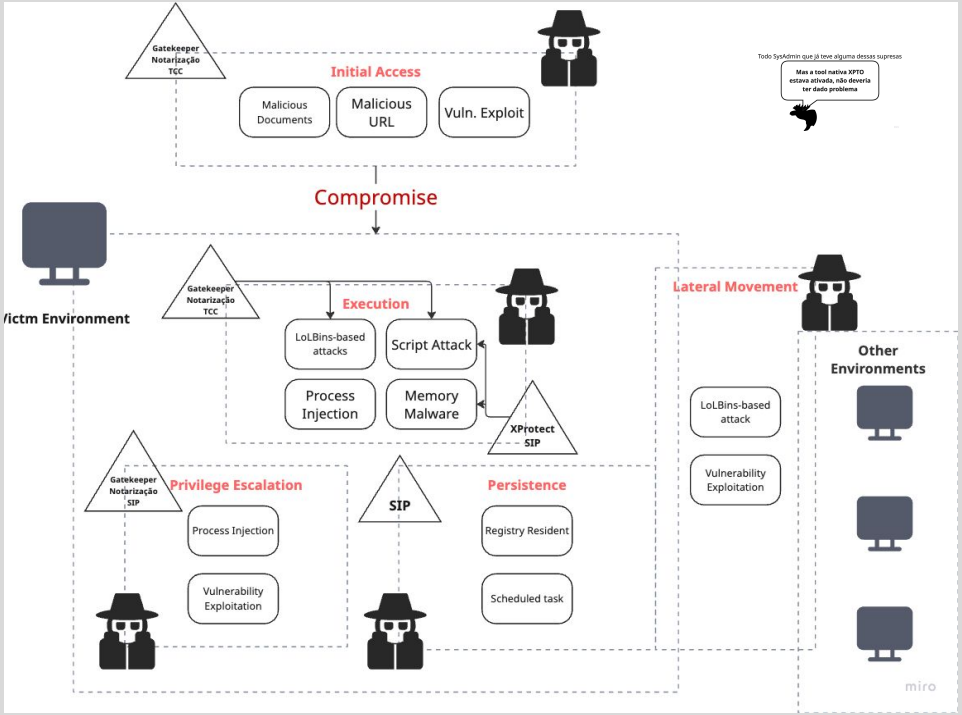
Gatekeeper:
- Função: Só permite instalação/ execução de apps da App Store e desenvolvedores identificados
- Como é Burlado: Atacantes obtém certificados de desenvolvedor roubados ou simplesmente pedem para o usuário clicar com o botão direito e "Abrir"

XProtect (Antivírus Nativo):
- Função: Checar assinaturas de malware conhecido
- Como é Burlado: Ofuscação de código, malware polimórfico e assinaturas desconhecidas tornam-no ineficaz contra ameaças novas.

Notarização:
- Função: A Apple verifica software de desenvolvedores identificados em busca de malware
- Como é Burlado: O malware só é detectado ***após*** ser reportado. Há uma janela de oportunidade para os atacantes

System Integrity Protection (SIP):
- Função: Proteger arquivos e pastas críticas do sistema
- Como é Burlado: Ataques modernos focam em áreas não protegidas pelo SIP, como a pasta `Home` do usuário

TCC (Transparency, Consent, and Control):
- Função: Solicita permissão ao usuário para acessar Câmera, Microfone, Arquivos de Área de Trabalho/Documentos, etc.
-Como é Burlado: Engenharia social para convencer o usuário a clicar em "Permitir". Ou abuso de aplicativos legítimos que já têm a permissão



Eeeeeeee todo o resto…

Malware (Usuário Final)

- **Adware & PUPs:** Softwares “inocentes” que vêm com brinde (anúncio, barra, caos)
- **Trojans Bancários:** Falsas atualizações pedindo senha (Spoiler: não era o Flash Player…)
- **Ransomware:** “Patch mágico” que vira sequestro de arquivos.

Engenharia Social & Phishing

- **Apps Falsos:** Slack/Zoom do *universo paralelo* roubando credenciais
- **Pop-ups Safari:** Sites pedem “notificações” → viram spam malicioso infinito
- **iMessage Phishing:** Links de entrega, banco ou drama — tudo golpe.

Exploits & Vulns

- **Zero-Days:**
  - Safari + Kernel = combo gourmet para atacantes avançados
- **Fileless:**
  - Código rodando direto na memória, sem arquivo pra culpar
- **Supply Chain:**
  - Software legítimo infectado na fonte (tipo XCodeGhost)

Persistência & Evasão

- **LaunchAgents/Daemons:**
  - `.plist` que renasce a cada boot
- **Perfis (.mobileconfig):**
  - Proxy, certificados falsos e configurações “possuídas”
- **Cron Jobs:**
  - Tarefas maliciosas escondidas no sistema
- **Injeção de DYLIB:**
  - App legítimo carregando biblioteca maliciosa sem saber

Geralmente quem gera a brecha não tem propósito malicioso…
Quem costuma burlar o quê, onde e POR QUÊ?

XProtect (Antivírus nativo)

- **Usuários que baixam arquivos da internet com frequência**, especialmente arquivos ZIP, DMG ou instaladores menos conhecidos.
- **Usuários que lidam com anexos externos** (vendas, administrativo, financeiro).
- **Usuários com hábito de instalar "cracks", "free trials quebradas" ou plugins alternativos** (comum em times criativos).

Por quê:
- Dependem de conteúdo externo e variado → mais exposição a malware que ainda não tem assinatura.
- Muitas ameaças chegam por e-mail, e XProtect não detecta variantes novas ou polimórficas.

Gatekeeper

- **Usuários que instalam muitos apps de terceiros (designers, desenvolvedores, engenharia, marketing com ferramentas externas).**
- **Usuários com baixa maturidade de segurança, que clicam para "forçar abrir" apps desconhecidos**

Por quê:
- **Precisam instalar ferramentas fora da App Store → ficam "irritados" com bloqueios.**
- **Estão acostumados a seguir tutoriais/YouTube que mandam "clique com o direito → Abrir".**
- **Maior propensão a aceitar apps com certificados inválidos por frustração com a restrição.**

System Integrity Protection (SIP)

- **Usuários avançados / power users** que tentam modificar configurações do sistema.
- **Desenvolvedores que precisam acessar áreas bloqueadas**.
- **Equipes de suporte que usam ferramentas antigas que dependiam de mexer em /System**.

Por quê:
- Software pequeno/obscuro muitas vezes não segue o fluxo completo de notarização.
- Binários internos mudam rapidamente e nem sempre são enviados à Apple para análise.
- Notarização detecta malware só depois da denúncia → usuários early adopters são mais atingidos.

TCC (Transparency, Consent, and Control)

- **Usuários ansiosos que clicam "Permitir" para tudo** para se livrar do pop-up.
- **Usuários que usam apps de produtividade que pedem permissões demais** (ex.: apps de screenshot, reuniões, anotações).
- **Usuários que não entendem impacto de dar acesso ao Desktop/Documents**.

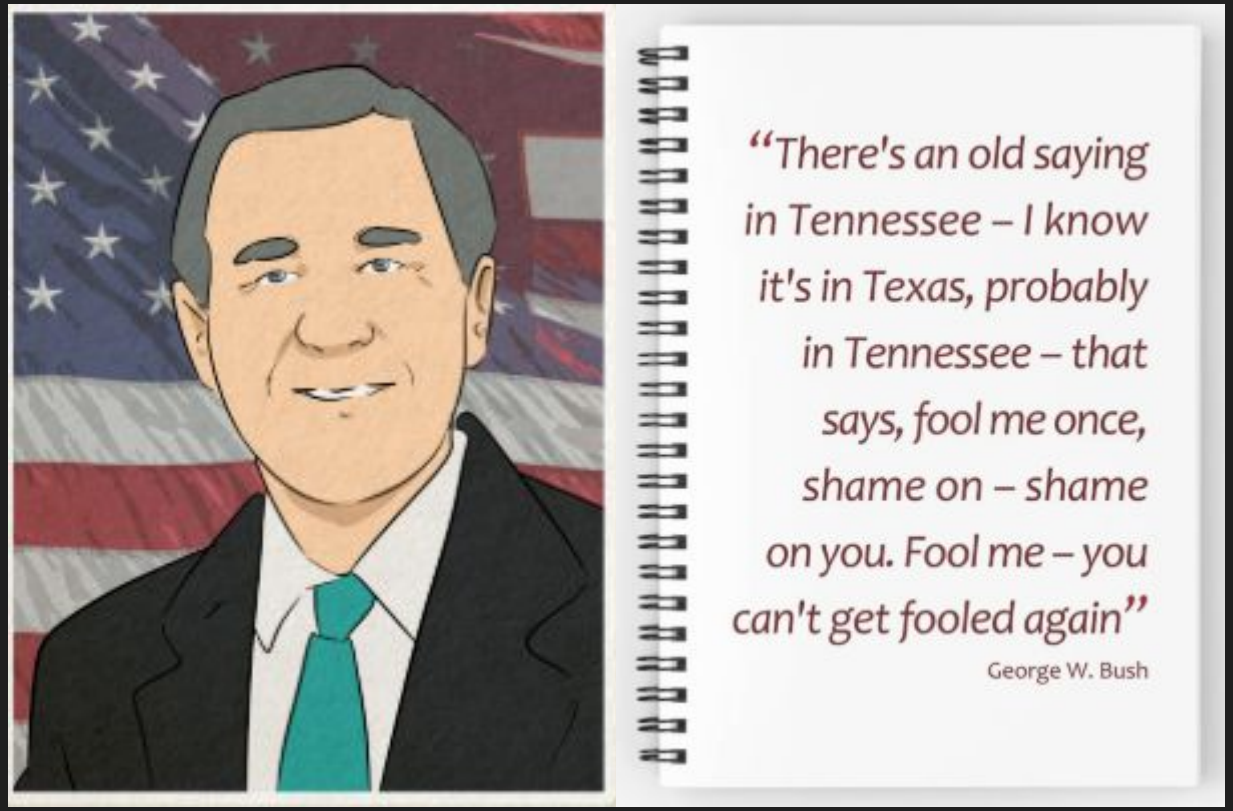
Por quê:
- TCC depende totalmente do bom senso do usuário.
- Pop-ups são ignorados rapidamente ("quero usar logo!").
- Engenharia social funciona muito bem ("Clique permitir para continuar").
- Apps legítimos já aprovados podem ser abusados para acessar áreas sensíveis.

Notarização

- **Usuários que trabalham com software de nicho** (CAD, engenharia, ferramentas legacy).
- **Desenvolvedores internos** rodando binários que não passaram por notarização.
- **Equipes com soluções internas assinadas mas não publicadas**.

Por quê:
- Software pequeno/obscuro muitas vezes não segue o fluxo completo de notarização.
- Binários internos mudam rapidamente e nem sempre são enviados à Apple para análise.
- Notarização detecta malware só depois da denúncia → usuários early adopters são mais atingidos.

Benchmarks, Ferramentas & Projetos: Como Escolher com Intencionalidade



Nós deveríamos começar discutindo sobre projetos, mas vamos começar por ferramentas…

Regrinhas:

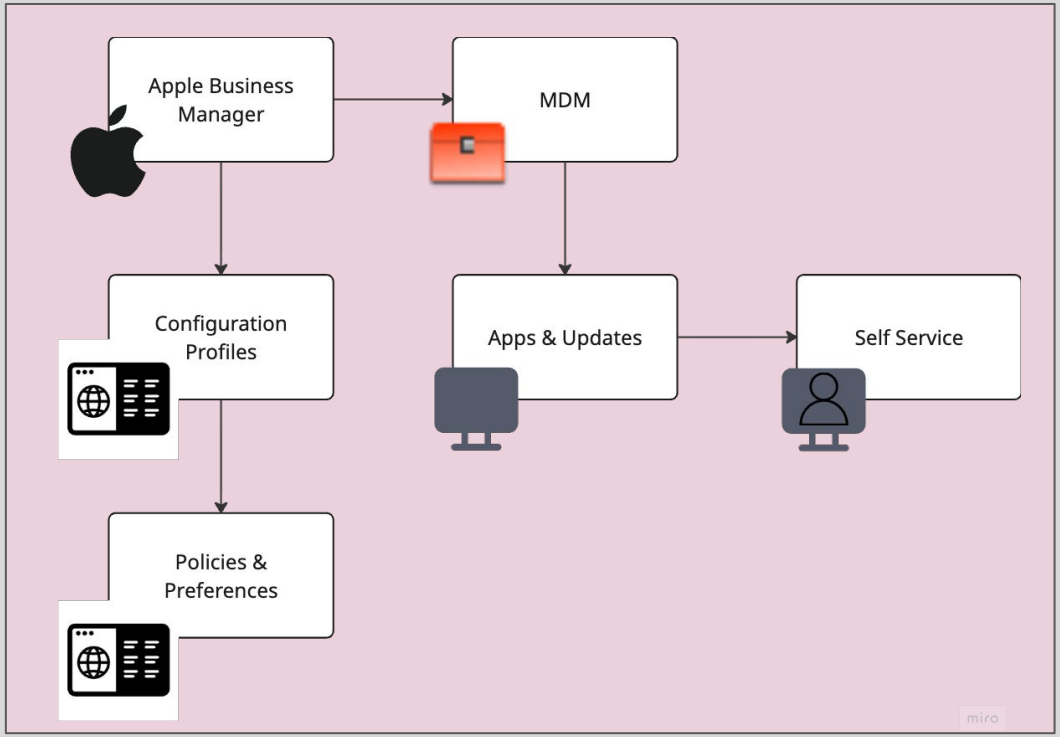
-> Sem redundância

->Sem marketing

Desculpe fãs de quadrantes mágicos,

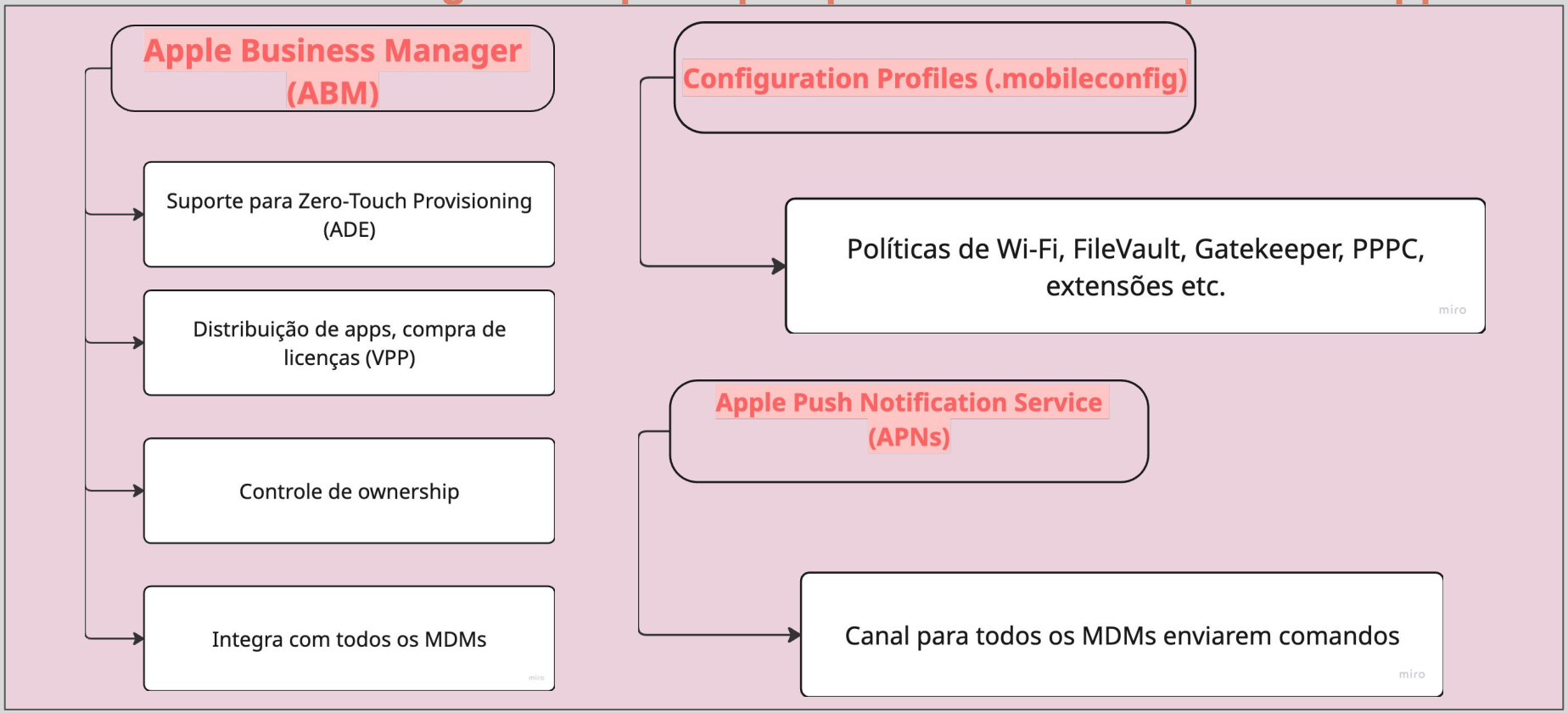
->Só o que realmente importa para quem gerencia Macs profissionalmente

As vezes é mais fácil de entender o esquema de administração fuçando a caixinha de ferramentas…



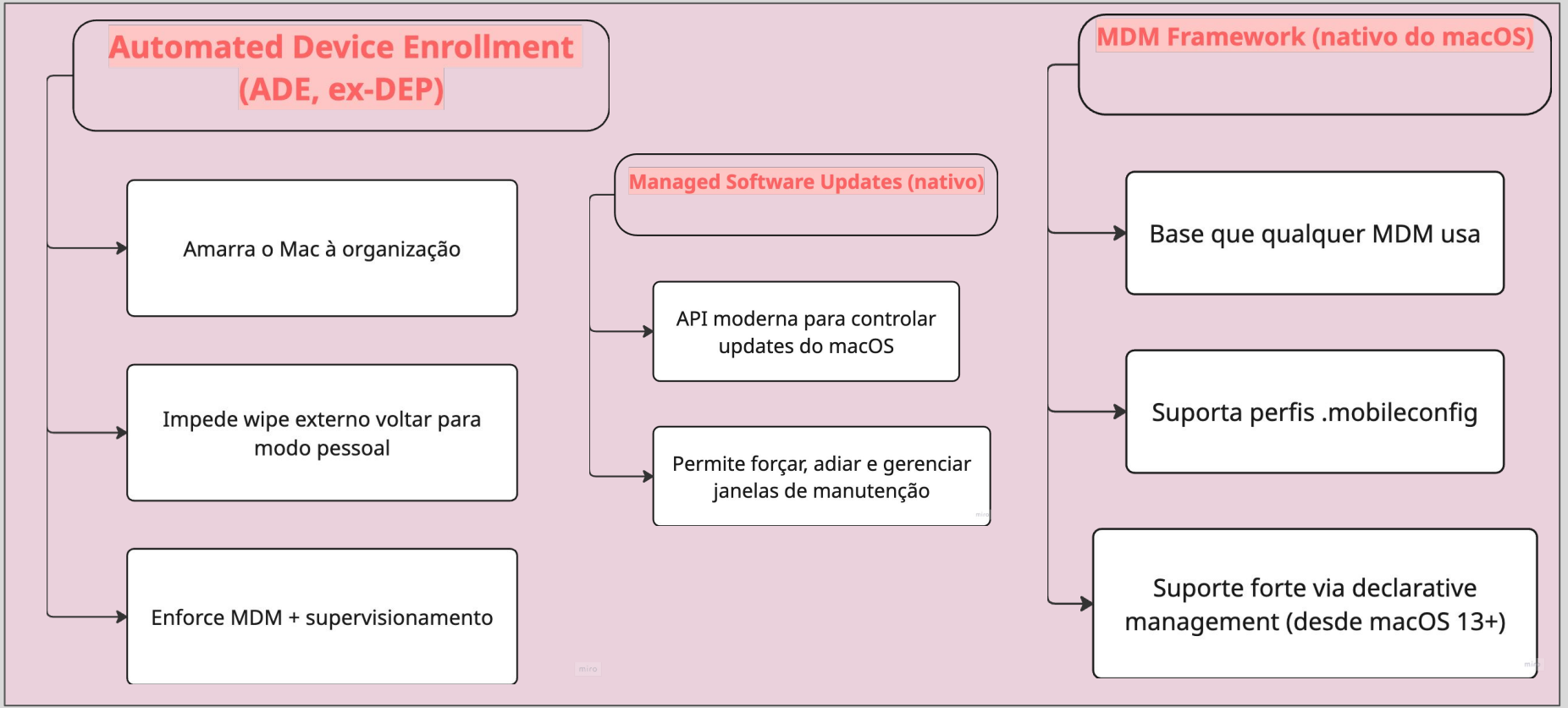
Ferramentas Nativas da Apple (Core do ecossistema)

Essas são obrigatórias para qualquer ambiente corporativo Apple



Ferramentas Nativas da Apple (Core do ecossistema)

Essas são obrigatórias para qualquer ambiente corporativo Apple



Ferramentas Nativas da Apple (Core do ecossistema)

Essas são obrigatórias para qualquer ambiente corporativo Apple

Negligência	Curto Prazo	Médio Prazo	Longo Prazo
ABM	Onboarding manual	Dispositivos fora do controle	Shadow IT + perda de patrimônio
ADE	Remoção de MDM	Falha em FileVault/PPPC	Sem ownership corporativo
MDM Framework	Configs quebrando	Scripts frágeis	Gestão que não escala
Perfis .mobileconfig	Pop-ups e erros	Hardening inconsistente	Compliance nunca 100%
Managed Updates	Updates caóticos	Fragmentação	Exposição a CVEs
APNs	MDM para	Re-enroll manual	Colapso da gestão

MDMs Comerciais focados ou compatíveis com MacOS

Novamente, não tem quadrante aqui…

Apple-focused (MDMs especializados em Mac)

- Jamf Pro
- Kandji
- Mosyle Business / Fuse
- Addigy

Tem Open Source Também…

- MacAdmins Open Source Projects (MACAD)
  - Conjunto de ferramentas usadas por MacAdmins do mundo todo
- Installomator
  - Script universal para instalar/atualizar softwares no macOS
  - Usado por Jamf, Kandji, Mosyle e Intune

MDMs Multiplataforma (incluem macOS)

- Microsoft Intune
- VMware Workspace ONE (AirWatch)
- IBM MaaS360
- Hexnode
- ManageEngine MDM Plus
- JumpCloud MDM
- SOTI MobiControl
- Google Endpoint Management (limitado para mac)

E se não é um MDM, provavelmente está na lista aqui em baixo…

Ferramentas de segurança nativas ou usadas para hardening

- XProtect (antivírus nativo)
- Gatekeeper
- TCC / PPPC (controle de permissões de apps)
- XProtect Remediator (anti-malware no nível de sistema)
- System Extensions / EndpointSecurity Framework
- FileVault 2
- Firewall + Stealth Mode
- System Integrity Protection (SIP)
- Xcode Notariszation (para apps internos)

Essas ferramentas não são MDM, mas fazem parte da gestão do estado de segurança do macOS e precisam ser controladas por MDM.

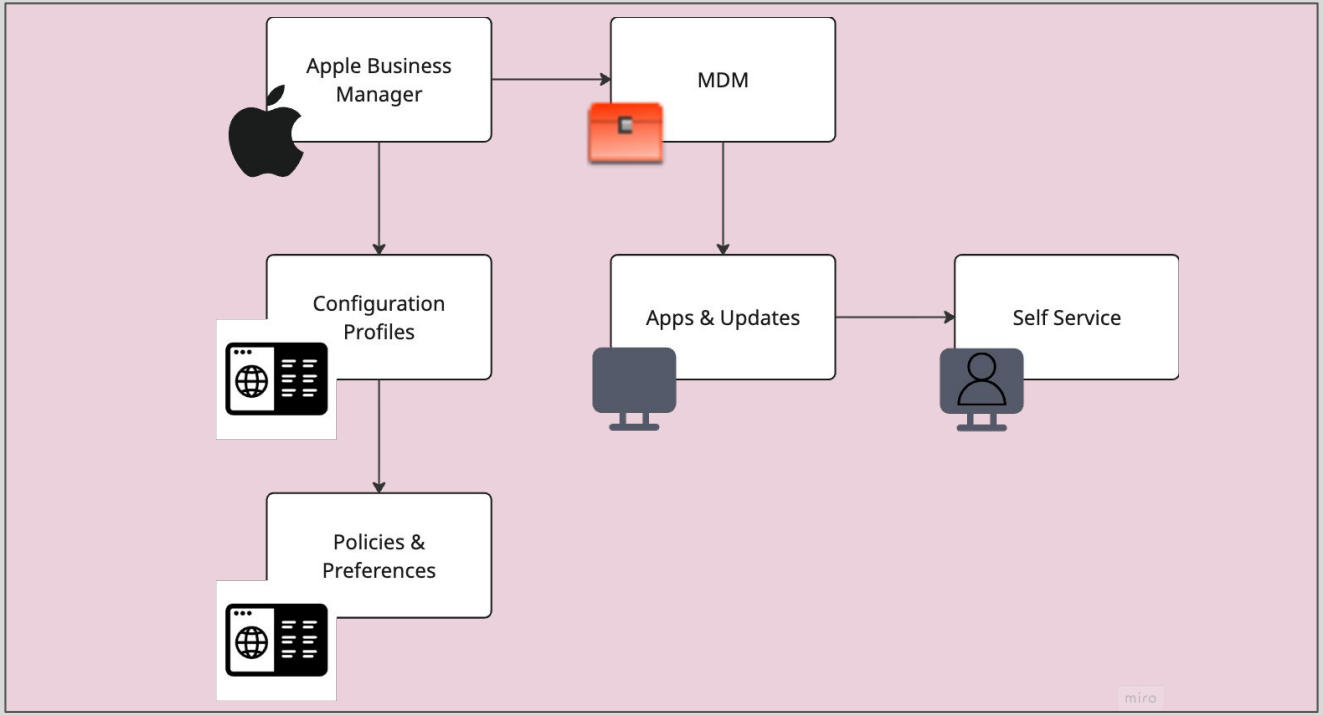
Ferramentas corporativas auxiliares (usadas por times de Client Eng / SecOps)

Configuração / Deploy
- pkgbuild / productbuild (nativo)
- AutoPkg
- AutoPkgr GUI
- createuserpkg

Inventário / Compliance
- Osquery
- Elastic Agent
- CrowdStrike Falcon (não é MDM, mas crítico para gestão)
- SentinelOne
- Carbon Black

Observabilidade e Fleet Management
- FleetDM (osquery-based)
- Kandji Telemetry
- Jamf Protect (agora Jamf Security Cloud)

Fez sentido até aqui?



Então bora ver como podemos descobrir a maturidade do nosso parque

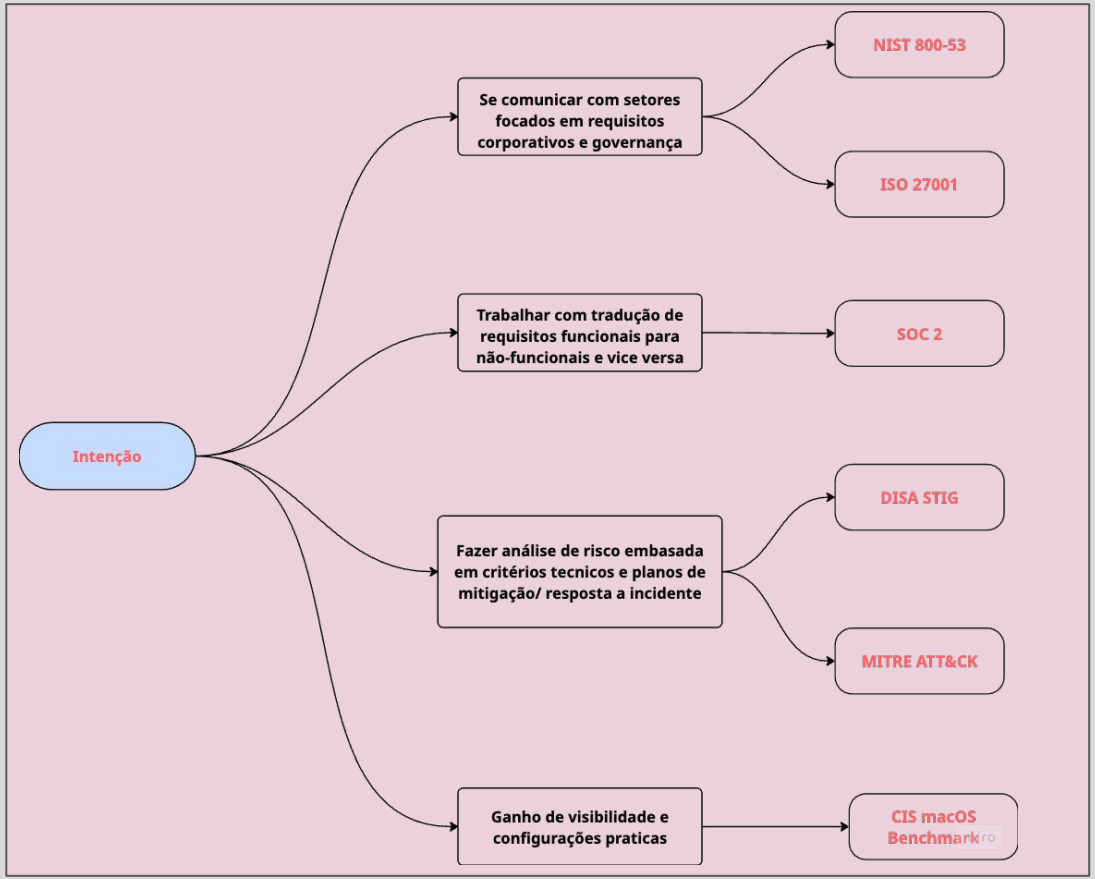
Não me olha com essa cara, tinha compliance escrito no título

Como decidir qual framework usar em qual contexto

Intenção / Objetivo	Framework Adequado	Por quê
Hardening técnico direto do macOS (operacional)	CIS macOS Benchmark	Configurações práticas, específicas por versão e arquitetura. Fácil automatizar (Intune, Jamf, shell).
Hardening máximo e requisitos militares / defesa	DISA STIG	Controles extremamente rígidos e prescritivos, padrões DoD.
Compliance governamental ou baseline corporativo alto nível	NIST 800-53	Framework de controles; CIS/STIG servem como implementação técnica.
Governança e Sistema de Gestão de Segurança (ISMS)	ISO 27001	Não define hardening; usa CIS/NIST como evidência de controles técnicos.
Auditorias de serviço / certificações de segurança (Trust Services Criteria)	SOC 2	A auditoria requer evidências de hardening; CIS é o padrão aceito para demonstrá-las.
Threat modeling baseado em técnicas reais de ataque	MITRE ATT&CK	Permite mapear quais controles CIS/STIG mitigam cada TTP.
Priorizar quais controles endurecer primeiro	MITRE ATT&CK + CIS	Você liga cada técnica relevante ao controle CIS correspondente.
Justificar controles para diretoria/compliance	NIST 800-53 + ISO 27001	Tradução do hardening técnico para governança e requisitos corporativos.

A escolha do framework depende da sua necessidade!

Detalhe, essa lista não é nem de longe uma lista exaustiva de normas e frames...



Vamos focar em visibilidade e configurações práticas (CIS Time!!!)

CIS macOS Benchmark

- Estrutura: Níveis L1 (baixo impacto) e L2 (alta segurança)
- Categorias: Sistema, Rede, Atualizações, FileVault, Firewall, Logs, Serviços
- Relevância: Redução de risco, compliance (NIST/ISO/SOC2), auditoria
- Integração: Suporte amplo via MDM (Intune, Jamf, Kandji, Mosyle)
- Entregáveis: Checklist, perfis MDM, scripts, relatório de gaps, pipeline contínuo
- Benefícios: Padrão aberto, atualizado, priorização por criticidade

Como o CIS enxerga o macOS

(Arquitetura para Avaliação, e mais tabelas…)

A lógica é sempre a mesma, não varia entre frameworks:
Identifica o objeto -> Define o estado desejado -> Executa comandos de Avaliação -> Compara com o valor esperado e classifica -> Gera ou uma sugestão de remediação ou um relatório (ou os dois…)

O CIS não avalia “apps” ou “ferramentas” isoladamente.
Ele avalia **objetos do sistema operacional** e **subsistemas de segurança nativos**

Camada / Objeto	Papel no macOS	Papel no CIS	Tipo de Avaliação
System Settings	Configurações persistentes	Maior parte dos controles L1	defaults, perfis MDM
Frameworks de Segurança	Gatekeeper, FileVault, SIP, TCC	Proteções críticas	Comandos nativos (spctl, fdesetup, csrutil)
Serviços/Daemons	Sharing, Remote Login	Desativar superfícies de ataque	launchctl, sharing
Atualizações/Anti-malware	XProtect, MRT	Garantir patching contínuo	Version check
Rede	Firewall, Stealth	Minimizar exposição	alf, network prefs
Logging/Auditoria	auditd, logd	Rastreabilidade	leitura de configs
Identidade/Autenticação	senha, sudo, loginwindow	Hardening de acesso	pwpolicy, dscl

Às vezes na vida, consertar o erro é mais fácil do que descobrir onde a gente tá errando…

No dia a dia de gestão de endpoints, é muito comum encontrar um padrão curioso: Todo mundo sabe configurar, aplicar um script, ajustar um perfil de MDM ou empurrar uma política para deixar o macOS “aderente” a um critério.

E mais comum ainda quanto isso é ver pessoas que não sabem auditar se aquela máquina realmente está em conformidade — e muito menos como provar isso de forma estruturada, repetível e rastreável.

⚠️ Configurar não é o mesmo que comprovar.
E é aqui que entra o macOS Security Compliance Project (mSCP)

Espera, a gente não estava falando de CIS e MDM? O que esse mSCP tem a ver com o assunto?

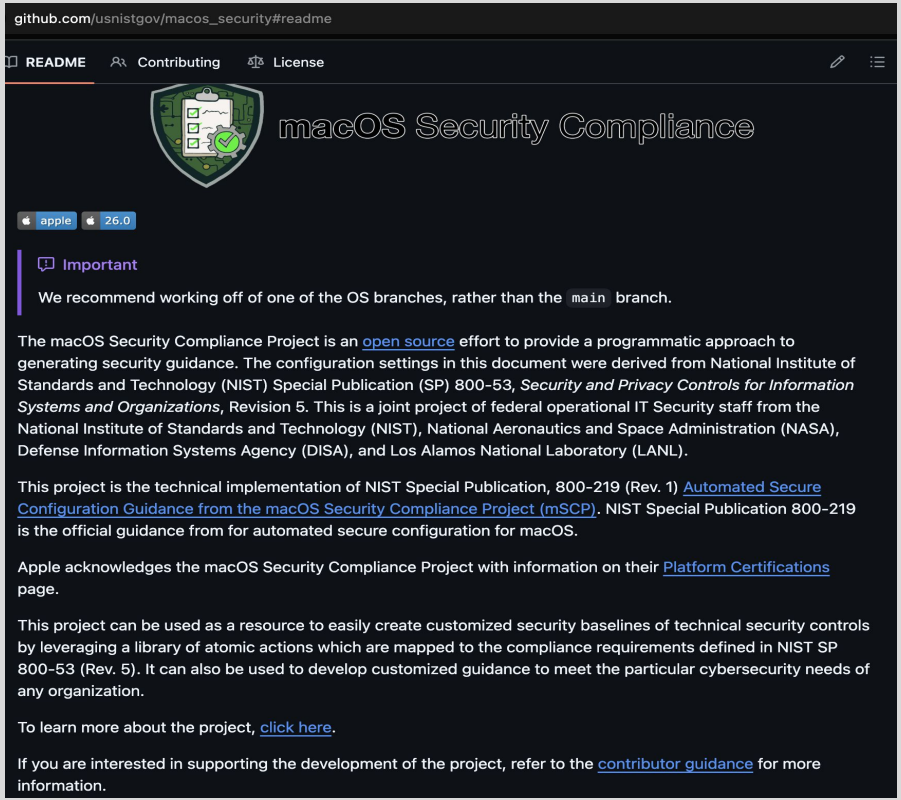
Porque o mSCP não substitui nada.
Ele não é MDM, não faz gestão, não distribui payloads, não inventaria dispositivos e não aplica políticas diretamente
O mSCP é um motor de compliance, não uma plataforma de gestão

Ou seja:

- Ele gera conteúdo (scripts, perfis, auditoria)
- Mas alguém precisa entregar esses conteúdos aos Macs — e isso é papel do MDM

O mSCP é a fábrica; o MDM é a logística

Por que isso importa no ecossistema Apple?



O macOS é altamente opinado e rigidamente controlado pela Apple:
há diferenças importantes entre Intel x ARM, versões, configurações gerenciadas, e escopos de permissão de MDM

O mSCP foi criado para lidar exatamente com isso, garantindo que a auditoria e a remediação sejam acuradas, compatíveis e não quebrem o sistema

Se o mSCP é tão bom… por que precisamos do MDM e todo o resto da parafernalha?

O que o mSCP resolve?

Ele elimina o gap clássico entre:
“Configurei, então deve estar certo” e “Comprove que está certo, Em todas as máquinas, O tempo todo.”

Ele é um projeto que ajuda a gente com:

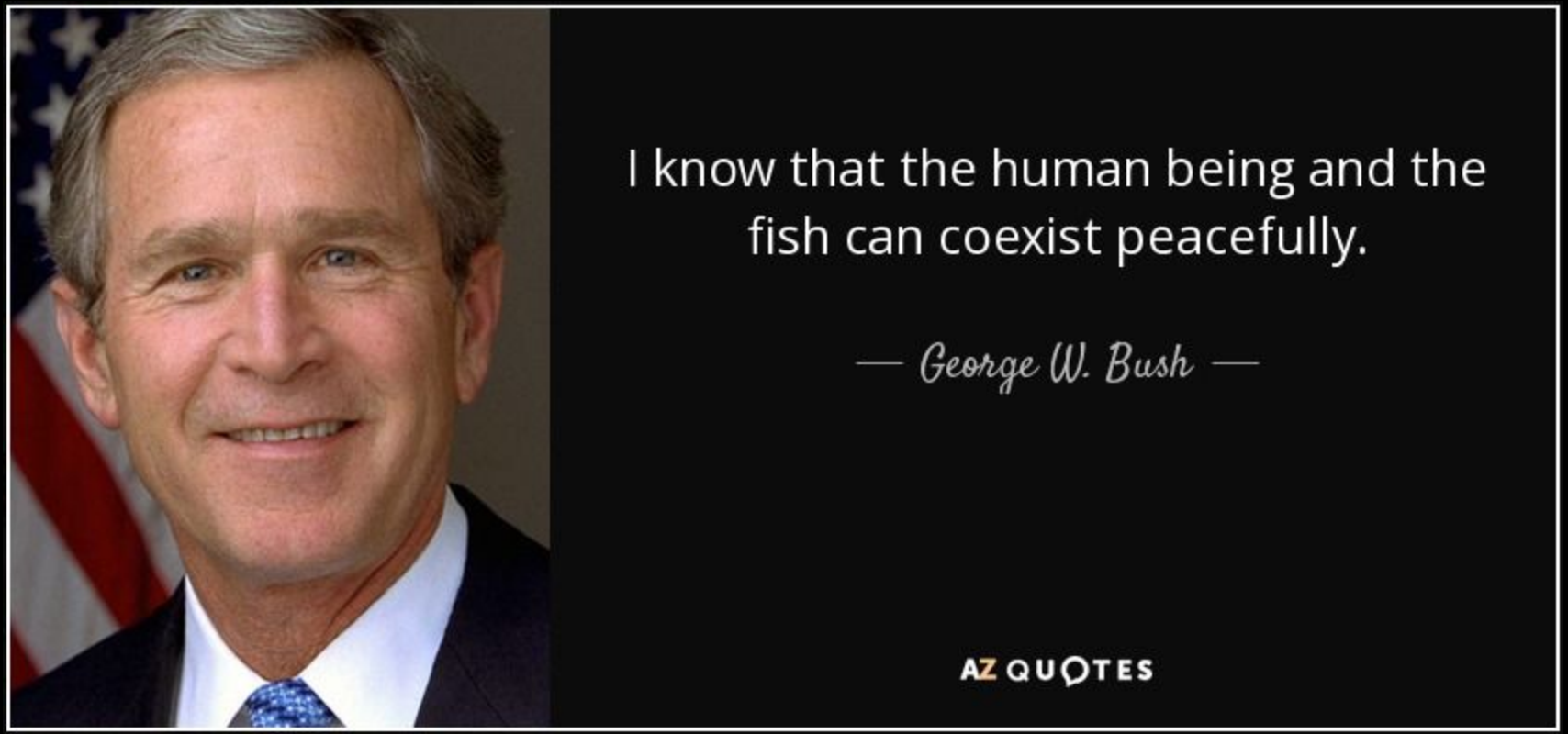
- Auditoria real → scripts que verificam cada regra
- Remediação padronizada → ações consistentes por versão e arquitetura
- Evidências → relatórios prontos para times de GRC, auditoria externa e SOC.
- Rastreabilidade → tudo versionado, documentado e reproduzível

mSCP e MDM não são concorrentes, são cúmplices

O mSCP define o que e como deve ser verificado/corrigido
O MDM define onde, quando e para quem isso será aplicado

Função	mSCP	MDM (Intune)
Gera conteúdo de compliance	✔️	—
Audita regras tecnicamente	✔️	Parcial
Remediação baseada em benchmark	✔️	Depende
Aplica perfis e scripts em escala	—	✔️
Inventário e monitoramento	—	✔️
Gestão do ciclo do dispositivo	—	✔️
Evidências e provas para auditoria	✔️	Parcial
Distribuição / orquestração	—	✔️

Containers e Virtualização no macOS



Quer matar um DEV que usa Mac de Raiva? Deixa ele sem containers e virtualização!

Tecnologia	Melhor Uso	Prós	Contras
Docker Desktop	Dev com containers	Fácil, GUI, Compose/K8s	Pesado
OrbStack	Dev moderno	Rápido, leve	Menos difundido
Colima	Containers via CLI	Leve, flexível	Configuração manual
Lima + Podman	Rootless containers	Integração sólida	Complexo p/ iniciantes

Recomendações

- Dev Web/Cloud: Docker Desktop ou OrbStack
- Leve/CLI: Colima
- Rootless/Infra: Lima + Podman

Essa sessão só existe para lembrar você que:

macOS não é só para quem quer parecer importante na call: devs também tiram (muito) proveito dele

Máquinas Virtuais no macOS

Ferramenta	Melhor Uso	Prós	Contras
Parallels Desktop	Windows/Linux com UI	Melhor performance, integração	Pago
UTM	Labs, múltiplas arquiteturas	Gratuito, versátil	Performance menor
VMware Fusion	Ambientes enterprise	Integração VMware	Pago (recursos avançados)

Cenários Comuns:

- Windows corporativo: Parallels
- Labs, pentest e multi-arch: UTM
- Integração com vSphere/ESXi: VMware Fusion

Rede de VMs:

- NAT: acesso à internet
- Bridge: VM como dispositivo real
- Host-only: isolamento para testes

A escolha depende muito do seu workflow específico. Para desenvolvimento moderno de software, **Docker Desktop + Parallels** cobre a maioria dos cenários.

Essa sessão só existe para lembrar você que:

macOS não é só para quem quer parecer importante na call: devs também tiram (muito) proveito dele

Performance, Kubernetes & Automação -

"O que você queria que alguém te contasse quando você estava no começando? "

Performance (Apple Silicon)
Prefira imagens ARM64

- docker run --platform linux/arm64 ubuntu
- Parallels/UTM → usar Apple Virtualization
- Containers → OrbStack/Colima são mais leves

Kubernetes Local:

- Minikube: minikube start --driver=docker
- Docker Desktop: K8s nativo (ativar nas configurações)

Resumão:

- Containers: Docker Desktop ou OrbStack
- Leve/CLI: Colima
- VMs: Parallels (produtividade), UTM (labs)
- K8s: Minikube/Docker Desktop

Scripts Úteis:

- Inicializar ambiente Dev:
  - start-dev-env.sh
- Backup de VMs:
  - vm-backup.sh

Se você ainda não fez os seus, faça

Essa sessão só existe para lembrar você que:

macOS não é só para quem quer parecer importante na call: devs também tiram (muito) proveito dele

Gestão de Ambientes Híbridos



Realidade dos Ambientes Híbridos

Ambientes Modernos = Diversidade

- Mistura de macOS + Windows + Linux + dispositivos móveis + cloud
- Ferramentas diferentes, políticas diferentes, times diferentes
- O objetivo não é “uniformizar”, mas integrar sem fricção

Desafios Comuns

Conformidade e segurança fragmentadas

- Ferramentas que funcionam bem em um SO, mas não no outro
- Suporte técnico heterogêneo
- Pipelines de Dev/DevOps distribuídos

Ambiente híbrido não é bagunça: é **estratégia!!!!!!!!!**
Se todo mundo usa coisas diferentes, a ferramenta certa é a que cria pontes.

Escolher Ferramentas em Ambientes Diversificados

Tenha Critérios Objetivos:

- Compatibilidade real (Mac, Windows, Linux + ARM vs x86)
- Operação consistente: CLI, API, automação
- Integração corporativa: IdP, MDM, SIEM, CI/CD
- Portabilidade: containers, VMs, infra-as-code
- Suporte a arquiteturas modernas (Apple Silicon, cloud-native)
- Overhead vs produtividade:
  - Ex.: Docker Desktop (completo)
  - Colima/OrbStack (leve)
  - Parallels/UTM (para VMs completas)

Regra do dedão: Escolha aquilo que roda em todos os times e automatize o que não roda nativamente.
Seu ambiente não precisa ser igual — só precisa funcionar junto

Convivência do MacOS com outros S.O

Padrões para Coexistência

- Containers: Docker/Podman/Colima → mesma CLI em qualquer SO
- Orquestração: Kubernetes/Helm → abstrai diferenças
- Versionamento: Git → unifica fluxo e cultura
- Automação: Ansible/Terraform/GitHub Actions → independente de OS
- Virtualização: Parallels/UTM/VMware → Mac executa o que faltar
- MDM/MAM: Intune + MDM próprios de macOS → coexistência controlada

Boas Práticas

- Padronize scripts cross-platform (bash, zsh, Python)
- Evite ferramentas “Windows only” ou “Mac only”, sempre que houver opção nativa
- Use VMs ou containers para eliminar gaps de compatibilidade
- Documente fluxos únicos e deixe o OS ser apenas meio, não obstáculo

No fim do dia, não importa se o time usa macOS, Windows, Linux…Importa que tudo compile, suba e rode — de preferência antes da daily

Bora cometer erros NOVOS agora galera !!!



If we don't succeed, we run the risk of failure.

— Dan Quayle —

**Dúvidas, Desabafos,
Pedidos de explicação
sobre alguma piada
tosca da apresentação ?**

AZ QUOTES